

DeepCode AI Fix: Fixing Security Vulnerabilities with Large Language Models

Berkay Berabi
berkay.berabi@snyk.io
Snyk
Zurich, Switzerland

Alexey Gronskey
alex.gronskiy@snyk.io
Snyk
Zurich, Switzerland

Veselin Raychev
veselin.raychev@insait.ai
INSAIT, Sofia University
Sofia, Bulgaria

Gishor Sivanrupan
sgishor@gmail.com
Zurich, Switzerland

Victor Chibotaru
victor.chibotaru@snyk.io
Snyk
Zurich, Switzerland

Martin Vechev
martin.vechev@inf.ethz.ch
ETH Zurich
Zurich, Switzerland

Abstract

The field of automated program repair has attracted substantial interest over the years, but despite significant research efforts, creating a system that works well for complex semantic bugs such as security vulnerabilities has proven difficult. A promising direction to addressing this challenge is by leveraging large language models (LLMs), which are increasingly used to solve various programming tasks such as code generation.

In this paper, we investigate the effectiveness of LLMs for solving such code-repair tasks. We show that the task is difficult as it requires the model to learn long-distance code relationships, a task that inherently relies on extensive amounts of training data. At the same time, creating a large, clean training or evaluation datasets for complex program bugs and their corresponding fixes is costly and non-trivial. We propose a technique to address these challenges with a new approach for querying and fine-tuning LLMs. The key idea is to leverage program analysis to limit the LLM’s attention mechanism on the portions of code needed to perform the fix, drastically reducing the amount of required training data. Concretely, for both training and inference, rather than feeding the entire program to the LLM, we reduce its code to a much shorter snippet that contains the reported defect together with the necessary context – and use that instead.

Our evaluation shows that this code reduction approach substantially improves both readily available models such as GPT-4 using few-shot learning, as well as fine-tuning models. To train and evaluate our system, we also created a new and comprehensive code fixing dataset by extensively labeling 156 non-trivial bug patterns (including 40 security rules).

These patterns are non-trivial and require complex interprocedural dataflow to discover. Our best resulting system based on Mixtral-8x7B can remove more than 80% of the reported defects while exactly matching the human fix in between 10 and 50% of cases, outperforming baselines based on GPT-3.5 and GPT-4, or based on window-based models such as TFix.

1 Introduction

The rapid increase in the number of software systems has led to an increased demand for methods and tools that can detect potential defects in these systems. Indeed, existing testing and bug-finding tools, ranging from test generation to dynamic and static analysis, often return thousands of high-quality findings [5]. However, due to the sheer volume of discovered defects, most of the reports are not addressed by developers. Despite various efforts aiming to improve the development process and improve the situation [45], the most promising long-term path to addressing this issue in a systematic manner remains automatic bug fixing.

Prior to using large language models (LLMs), automated fixing tools mostly focused on a small set of bugs [28], trivial few-line changes [10, 46] or formatting issues [11, 28]. As LLMs were created, it was shown that they can also be useful in fixing lint-like issues [4, 24]. With even larger LLMs, a number of software security providers announced features that mostly use OpenAI GPT models [35, 36] in an attempt to automatically fixing more complex security issues discovered by static analyzers [30, 47]. Other security providers announced automatic fixing tools based on custom trained models [50, 53]. However, outside of marketing materials that display the user interface of these tools, there is little understanding of the underlying accuracy of the provided fixes. One of our contributions in this work is to address this issue by designing a dataset of vulnerabilities and their fixes, using which one can now evaluate the capabilities of existing and as well as any models proposed in future.

A dataset of security and semantic code fixes. To address the lack of evaluation data, we performed data collection and labeled thousands of commits collected from open

Permission to make digital or hard copies of part or all of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for third-party components of this work must be honored. For all other uses, contact the owner/author(s).

February 2024, Zurich, Switzerland

© 2024 Copyright held by the owner/author(s).

source repositories. Using 380'000 candidate fix commits and tens of labelers with coding and security background, we assembled a dataset of over 5'000 manually labelled fix examples. We then split this data according to the licenses of the code – permissively licensed data can be used for training or fine-tuning, and other data used only for evaluation. Using this method, we could protect against train/test leakage in evaluations as some of the models we use (like StarCoder [25]) are trained only on permissively licensed data. Our dataset is based on code scanning results of Snyk Code SAST engine [51]. Snyk Code operates on source code and is one of the fastest engines [49] with an extensive set of security rules. Each fix in our dataset consists of code where there is an alarm raised by Snyk Code and code where the alarm is not raised. In addition, human labelers agreed that the change correctly fixes the given alarm. Thus, our dataset has its result validated by a human that confirmed the change was not due to false positives or false negatives of the engine.

Key challenge: difficult to obtain training data. A core challenge when using machine learning for program repair is that it is inherently difficult to obtain a sufficiently large, clean dataset consisting of pairs of buggy and fixed code versions for a given program issue. While the history of many open source projects is available on GitHub, obtaining a dataset of fixes has so far only been done successfully for simple few-line local static analyses [4, 24]. The reason underlying this difficulty is that with deeper semantic issues, it is possible to observe program changes where a defect report is present in one version and absent in another, yet the core program error is not fixed. For example, the change may turn a problematic branch into dead code, some unrelated change may accidentally make a security vulnerability in the code exploitable, a code change may modify many more places than the bug or the change may affect the approximation of the static analyzer without affecting the actual presence of the reported issue. We investigate the frequency of these problems in Section 4.

Key challenge: the need to learn long-distance relationships. At the same time, the nature of fixing semantic program errors is such that correct fixes must understand long-distance relationships in the to-be-fixed code, yet learning such complex attention mechanisms expectedly requires large amounts of training data, which, as discussed above, is practically infeasible to obtain. Even if one somehow obtains such data, the inherent limitation in the context and output size of LLMs impedes their direct utilization both in fine-tuning and few-shot learning settings. While recent models have been developed to accommodate extensive context sizes, it is important to underline that supporting such dimensions in terms of computational resources and latency does not equate to effectively learning from long-range dependencies. If not constrained by input size, these models

still encounter challenges in handling tasks with prolonged contextual requirements and also often exhibit constraints in the number of output tokens beyond a certain threshold. Overall, this means that a direct application of LLMs (even state-of-the-art) on this task, as illustrated in Figure 1 (a), is unlikely to work well.

We remark that our experiments with directly applying extensively pretrained models such as GPT-4 led to worse result on complex bugs in comparison to applying the same technique on simple few-line bugs.

This work: Code-Reduced Dataset & LLM-based Code Fixing. In this work, we address the above challenges in two steps. **First, we perform extensive labeling of open-source commits and construct a clean dataset of issues and fixes for JavaScript programs.** Second, we propose a new approach that improves the learning and prediction capability of code models by leveraging static code analysis, in line with prior work, which showed that program analysis features can play a significant role in the quality of the learned model, having the same quantitative effect as adding (an order of magnitude) more labeled data [1, 18, 43]. Our technique is inspired by cReduce [44] – a tool originally used to minimize code snippets such that a compiler bug present in the original code is preserved in the minimized snippet. Instead of compiler bugs, here we reduce the input code such that a static analysis report in the original program is still reported by the same static analyzer in the reduced code snippet. The reduced snippet contains the core of the problem, meaning that it focuses the training of the attention mechanism to very few lines of code, in turn, *reducing the samples length of the required (and difficult to obtain) training data*. The code reduction technique serves as a way of context extraction that allows modeling long-range dependencies and makes the repair system independent of the original file size. Using code reduction, we obtain a new cleaned dataset, where each sample only contains code related to its particular issue. We visualize the entire process in Figure 1 (b). CODEREDUCE still allows us to use models pretrained on text and code while replacing the need to learn attention over entire files or large contexts. As the samples are much shorter, a language model can effectively learn to fix bugs in programs either with fine-tuning or few-shot learning. Once a new program needs a fix for a reported issue, its code is reduced, and the LLM then fixes this reduced code. The LLMs' output is then merged back into the original file by using a patch procedure similar to how git performs code patching. Interestingly, as code reduction dramatically decreases the input length fed into the model, it even enables the usage of models of standard attention length [40, 54] that can now attend to the entire reduced code snippet with a vanilla attention mechanism.

Importantly, an automatic bug-fixing tool should be immediately useful to developers inside their IDE, if the predictions can be done in real-time. CODEREDUCE makes real-time

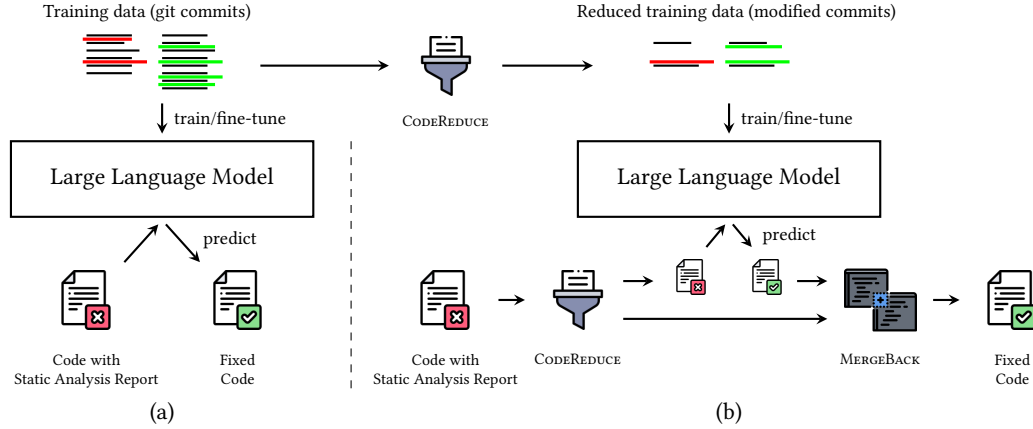


Figure 1. Pipeline for automatic bug fixing with (a) only a large language model or (b) with complete process proposed by DEEPCode AI Fix combining CODEREDUCE with a large language model.

serving possible as the number of tokens to be processed and to be generated by the model are significantly smaller than standard approaches. Moreover, to further improve real-time latency, we propose a speed-up over hierarchical delta debugging [32] based on provenance information from the static analysis tool. This extension reduces the calls to the underlying static analyzer by 30%, leading to a reduced latency.

1.1 Main Contributions

- A static analysis-enabled novel code reduction technique which produces a small representation of the program, one that easily fits into the attention window of a model, yet contains the necessary information for learning a correct fix.
- An extensive evaluation of several models both with fine-tuning (MIXTRAL, STARCORDERBASE, T5) and few-shot learning (GPT-3.5, GPT-4) on different datasets including reduced code, small window, long context and entire file.
- Algorithms for reducing code while preserving a static analysis alarm and then for merging the fixed reduced code prediction back into the original source file.
- An end-to-end code fixing tool DEEPCode AI Fix¹: substantially improving both readily available models like GPT-4 using few-shot learning, as well as fine-tuning models based on our extensive evaluations.

2 Overview of DEEPCode AI Fix

In this section, we present an overview of DEEPCode AI Fix on a motivating example that contains a security vulnerability. Figure 2 (a) shows a piece of JavaScript code that includes a server with a Path Traversal vulnerability [37]. There are static analysis tools that can discover this vulnerability and report it on the `frame-highlighted` line in the code. To fit the

figure, we significantly simplified the actual code example. In Figure 2 (b), we show a human-provided fix for this security vulnerability in a diff format. The human fix does not only contain the removal of the vulnerability but also includes an unrelated change `doBBB()` → `doXYZ()`.

Since the static analysis tool discovers the path traversal vulnerability in the code in (a) and does not discover it in the code in (b), this is a signal that the pair (a)→(b) qualifies as a potential training data sample for learning. To obtain an even cleaner data sample, DEEPCode AI Fix calls the CODEREDUCE component, which on its own calls the static analyzer multiple times until it produces the code shown in Figure 2 (c). Note that while the code is reduced, we discover which of the lines are essential for detecting the vulnerability: here, one needs to include the file system library to keep the server handler, and one needs to keep the data flow from the request to the file system operation. Note that there are multiple trivial but wrong ways to fix the code snippet in Figure 2 (c). For example, if any of its statements is deleted from this input, the vulnerability will disappear, however the program will also break its semantics in a significant way. This observation is important because it highlights that relying on simple heuristics to obtain training data is potentially dangerous. It can lead to models that trivially satisfy bug removal metrics but actually learn incorrect fixes.

To gain a useful fix sample, we take any change between (a) and (b) such that the line of this change is also included in (c) or adjacent to a line included in (c). Then we apply these changes to (c) and construct a sample, as shown in Figure 2 (d). Next, we validate that the provided fix parses and removes the static analysis alarm. Let this pair of code snippets (c) and (d) be denoted `REDUCEDPRE` and `REDUCEDPOST`, respectively. Let the static analysis report type be denoted `RULE/DESCRIPTION` – e.g. in the figure, the rule is PT identifying path traversal and description contains a short text about the vulnerability. Then, a large language model can

¹The work is available at https://github.com/BBerabi/deepcode_ai_fix



Figure 2. An example run of our data creation pipeline on a diff containing a path traversal vulnerability [37] fix (a)→(b). **Colors:** red -/green +/gray represent standard diff notation, and **framed line** marks the location of the vulnerability. CODEREDUCE is applied on (a), and a similar transformation is then applied on (b) to get (d), whereas MERGEBACK is applied to obtain (e) from (a) and the diff of (c)→(d). Other real-world fix examples generated by DEEPCODE AI FIX can be found in Appendix C.

be provided code fixing examples similar to (c) and (d) using the prompt:

```
fix RULE DESCRIPTION : REDUCEDPRE
```

be fine-tuned to generate REDUCED_{POST} given such a prompt. Note that because (c) and (d) are short code samples, they are expected to fit in the attention window of a text transformer and the learning can be efficient even with relatively few

training samples. The same prompt structure can be used for inference as well.

Assume that the LLM has learned to perform fixes on programs like (c). If we provide the input (a) as a query, DEEPCODE AI FIX will reduce the sample to program (c), the language model will transform it into (d), and then we need to merge back the resulting reduced fix program into the input program (a). This step, called MERGEBACK, is shown

in Figure 2 (e), and works by applying the changes observed between (c) and (d) onto the program (a).

It is a known problem that bug-fixing commits often contain patches irrelevant to the applied fix, such as refactorings [23]. Note that the procedure in Figure 2 is also useful for data cleaning. The first pair (a)→(b) is transformed into a pair (a)→(e) such that the unrelated change in the first pair like `doBBB()` → `doXYZ()` is removed. This side benefit of CODEREDUCE plays an important role for obtaining a clean dataset.

3 Core Components of DEEPCODE AI FIX

Next, we describe DEEPCODE AI FIX’s components.

3.1 Code Analysis

For code analysis, DEEPCODE AI FIX uses Snyk Code [51] – a proprietary commercial static analyzer that operates on source code. **In this work, we only evaluate with JavaScript/TypeScript analysis**, along with its extensions such as ReactJS and VueJS. As of January 2024, the analyzer implements 156 different checks that are in Appendix A. We classified them into five categories as follows:

AST: Most of the AST checks are ones that can be performed only on the abstract syntax tree (AST). Many of these rules enforce properties about the VueJS or React extensions of the language and include checks such as missing tags, duplicate variable names and patterns that usually do not depend on analyzing the control or dataflow of the program.

LOCAL: The LOCAL checks use interprocedural analysis to discover that certain incorrect values would flow into methods that would not accept them, to discover that resources are not deallocated or that certain expressions have no effect or always produce results with unexpected semantics.

FILEWIDE: The FILEWIDE checks also depend on interprocedural analysis, but in contrast to the LOCAL checks, the properties that they check always stay in different functions or methods in the program. These rules include checks for mismatches between the signature of a method, its implementation or its usage.

SECURITYLOCAL: Similar to the LOCAL checks, SECURITYLOCAL checks verify incorrect API usage from the security perspective as well as other types of security misconfigurations, typically by tracking the set of all method calls on an object or by tracking the values passed as parameters to method or function calls.

SECURITYFLOW: The SECURITYFLOW checks are usually the most complex checks supported by the selected static analyzer. This rule category includes all taint analysis rules that involve interprocedural dataflow analysis starting from a data source as well as the detection of various data sanitization patterns.

Approximate Provenance Information. In addition to reports, static analyzers typically provide proofs of the

reports, such as data flow or a flow describing the discovered defect. These, however, target human readability and are usually not the full set of program statements a static analyzer needs to reproduce the alarm. As a result, many existing analyzers provide approximate provenance that is either over-, or under- approximation of the precise provenance. Yet, even an approximation is useful to speed-up the CODEREDUCE algorithm. We assume the existence of a procedure that returns the approximate set of abstract syntax tree (AST) nodes required for a report. We define a function APPROXPROVENANCENODES that takes a list of tree nodes, a static analysis report and returns a list of nodes that participate in the derivation of the static analysis report.

3.2 CODEREDUCE

Given a file and a vulnerability detected by our static analyzer, DEEPCODE AI FIX calls CODEREDUCE to reduce the source code to a small snippet that still reports that static analysis alarm. CODEREDUCE is inspired by cReduce and delta debugging, which execute a set of transformation passes on the tree representation of the input code while checking that a detected property remains present in all of its transformation phases. In our case, all our transformations are performed on an AST and we base our algorithm on Hierarchical Delta Debugging (HDD) [32].

Algorithm 1 CODEREDUCE procedure based on HDD [32]

Input

C: source code;
tree: AST of the input code including the node locations in *C*;
report: the vulnerability and the AST node on which it was reported;

Output

c: reduced code;
l_{C→C}: line mapping;
1: *level* ← 0
2: *nodes* ← GETNODES(*tree*, *level*)
3: *c* ← *C*
4: **while** *nodes* ≠ ∅ **do**
5: *nodes*^{prov} ← APPROXPROVENANCENODES(*nodes*, *report*)
6: *c*^{prov}, *tree*^{prov}, *l_{C→C}*^{prov} ← REMOVENODESFROMCODE(*nodes* \ *nodes*^{prov}, *c*, *tree*, *l_{C→C}*)
7: **if** PARS(*c*^{prov}) ∧ REPORTEXISTS(*c*^{prov}, *report*) **then**
8: *nodes* ← *nodes*^{prov}
9: *c*, *tree*, *l_{C→C}* ← *c*^{prov}, *tree*^{prov}, *l_{C→C}*^{prov}
10: *c*, *tree*, *l_{C→C}* ← DDMIN(*nodes*, *report*, *c*, *tree*, *l_{C→C}*)
11: *level* ← *level* + 1
12: *nodes* ← GETNODES(*tree*, *level*)

HDD is itself based on a Delta Debugging [57] procedure DDMIN that is called for the nodes at each level of the AST of the currently reduced code. DDMIN takes as input a set of program elements (in our case AST nodes), a static analysis report and the code with its tree. Its output is a further reduced code with a reduced tree that still keep the static analysis alarm present in the program. DDMIN performs

```

const express = require('express');
const fs = require('fs');
express().post('/path', (req, res) => {
  var options = {
    dotfiles: fs.ReadFileSync('cfg')
  };
  res.sendFile(req.params.name, options);
});

```

Original Code

```

1 1 const express = require('express');
2
3 2 express().post('/path', (req, res) => {
4
5
6
7 3   res.sendFile(req.params.name, options);
8 4 });

```

 $l_{c \rightarrow c}$

Reduced Code

Figure 3. An example code reduction. The usage of the variable `options` remains in the reduced code, but its definition is deleted. The definition of `express` is not deleted because it is an import statement related to the vulnerability. The reduced code is not executable, but the analyzer can detect the path traversal vulnerability in both versions.

multiple attempts to remove tree nodes and calls the underlying static analysis multiple times to check the presence of the report. We refer to [57] for more details.

We modify the HDD procedure to take into account the approximate provenance information the static analysis alarm provides. Algorithm 1 describes the concrete procedure. It begins at the root node of the AST. At each level, the algorithm filters out the nodes that should be considered for deletion depending on the level in the tree (line 2). The provenance handling is shown in lines 5-9. The algorithm attempts to remove all nodes from the level that were not part of the approximate provenance and if the report is not removed (line 7), the removal is accepted. The remaining lines 10-12 continue as in the original HDD algorithm with a call to `DDMIN` on the nodes in the current level and moving to the next level. To maintain guarantees also when the provenance is approximate, the algorithm still performs the `DDMIN` procedure regardless of the success of the provenance nodes removal step.

To make `CODEREDUCE` useful for the automatic bugfixing case, we also modify `GETNODES` to only delete statements that are complete lines and avoid deleting lines only partially because partially deleted lines are harder to merge back into the original code. Additionally, we only consider nodes that delete statements and declarations but keep expressions inside statements. This means that for example, statements such as `call(arg1, arg2)` will not be reduced to `call()`, `call(arg1)` or `call(arg2)`.

When used as part of a loop until fixpoint, Algorithm 1 has the same 1-tree-minimality guarantees as in [32]. This means the returned code cannot be further reduced by removing any single node in the tree, such that the static analysis report remains present. The reason for a fixpoint loop is that a node on a higher level might become deletable only after having another node deleted on a lower level.

3.3 MERGEBACK

Even though `CODEREDUCE` brings many advantages, it comes with the cost of having predictions that are not directly usable. The reason is that the predictions, just like the model input, are also in a reduced form. Hence, to truly provide

end-to-end bug fixing, `DEEPCODE AI FIX` must merge the generated code back into the original file.

We present the `MERGEBACK` procedure in Algorithm 2. It starts by comparing the reduced input code c with the predicted fix p . This comparison uses `gitdiff` and aims to compute a one-to-many mapping $r_{c \rightarrow p}$ between the lines of c and p (line 1). For each line l_c in the reduced code c , $r_{c \rightarrow p}$ contains a potentially empty set of lines from the prediction p , by which the line l_c should be replaced. Technically, if l_c is mapped to l_p , we write that as $(l_c, l_p) \in r_{c \rightarrow p}$ and we assume iterations over this set return the elements in sorted order. Once the mappings are computed, the original non-reduced file C and the fix p are split into lines, and $\mathcal{L}_{\text{fixed}}$ is initialized to an empty sequence of strings (line 2).

Algorithm 2 Merging prediction back into the original file

Input

C : source code;
 c : reduced code;
 p : prediction on reduced code;
 $l_{c \rightarrow C}$: line mapping obtained from running `CODEREDUCE`;

Output

C' : resulting source code;
1: $r_{c \rightarrow p} \leftarrow \text{ComputeReplacementMapping}(c, p)$
2: $\text{Lines}_C \leftarrow \text{SplitLines}(C)$ $\text{Lines}_p \leftarrow \text{SplitLines}(p)$
 $\mathcal{L}_{\text{fixed}} \leftarrow \langle \rangle$
3: **for** $l_C \in \text{Lines}_C$ **do**
4: **if** $\exists l_c: (l_c, l_C) \in l_{c \rightarrow C}$ **then**
5: $\mathcal{L}_{\text{fixed}} \leftarrow \mathcal{L}_{\text{fixed}} \cup \langle l_p \in \text{Lines}_p \text{ s.t. } (l_c, l_p) \in r_{c \rightarrow p} \rangle$
6: **else**
7: $\mathcal{L}_{\text{fixed}} \leftarrow \mathcal{L}_{\text{fixed}} \cup \langle l_C \rangle$
8: **return** $\mathcal{L}_{\text{fixed}}.\text{join}("\n")$

After that, the algorithm iterates over the lines in the non-reduced input Lines_C (line 3) and checks for each line whether it is used in the reduced code or not (line 4). If a line does not participate in the reduced code c , it implies that the line is not important for the bug fix and the model does not see this line while generating the prediction. Therefore, that line must be kept as is, so we append this into $\mathcal{L}_{\text{fixed}}$ (line 7). In the other case, the prediction must decide how the line should be replaced. Therefore, we look up in $r_{c \rightarrow p}$ to obtain the list of prediction lines meant to replace the current line and add each of them to $\mathcal{L}_{\text{fixed}}$ (line 5). In the

<pre>import express from 'express'; import bodyParser from 'body-parser'; const app = express(); app.disable('x-powered-by'); app.use(bodyParser.urlencoded());</pre>	<pre>1 1 1 2 2 3 3 4 4 5 4 6 5 7</pre>	<pre>import express from 'express'; import helmet from 'helmet'; import bodyParser from 'body-parser'; const app = express(); app.use(helmet()); app.use(helmet.hsts()); app.use(bodyParser.urlencoded());</pre>
Reduced code c	$r_{c \rightarrow p}$	Prediction p

Figure 4. An example illustrating diff hunks between reduced code c and prediction p and the computed mapping $r_{c \rightarrow p}$ between them.

end, the algorithm joins the fixed lines $\mathcal{L}_{\text{fixed}}$ by the new line character and returns the result (line 8). Finally, the algorithm depends on computing $r_{c \rightarrow p}$. This is done by essentially doing a `git diff` and obtaining the so called "hunks" of corresponding mapped pieces of code. For each hunk, we calculate the corresponding line mapping as visualized in Figure 4.

4 Data Collection

In this section, we investigate the problem of collecting commit data and cleaning it up for building a repair tool. Our dataset is built from a large-scale crawl of GitHub that includes the top 500k repositories sorted by the number of stars. From these repositories, we selected all commits that do not merge branches, do not do file renaming, affect JavaScript and both versions of the code parse correctly and have appropriate code license. This resulted in a dataset of 6 million commits. We applied the static analyzer on all commits and obtained around 380 thousand (pre-, post-) file pairs that fixed a static analysis report – this means that a certain report was present in the pre-version of the pair and not reported anymore at the corresponding location in its post-version. The statistics about fixes are summarized per report type in the second column of Table 1. Note that this number of samples is still overly optimistic about the amount of training data usable for learning.

To check the data quality, we randomly sampled 50 file pairs removing reports from each of the five categories and manually evaluated if the change contains a proper fix for the issue at hand. Our findings are in columns 3-7 of Table 1. Overall, the table shows that a significant amount of the file pairs have fixed the issue in a way that a model cannot and should not utilize for learning. The most frequent problem is that instead of a good fix (column 3), the code is deleted or refactored (column 4).

A more interesting observation, though, was that as the complexity of a static analysis report increases, the probability of observing a correct fix drops significantly. Security issues are often left unfixed in code but are frequently removed or moved to another location as part of a refactoring. We also observed some cases of accidental fixes (column 5), where the affected code was turned into dead code, or an unrelated change removed a particular report. Besides, the

static analyzer is also not bullet-proof precision-wise. A few instances resulted in approximations that caused the analyzer to report false positives or under-approximations that caused the analysis to drop the report although no proper fix was applied (column 6). For some issues, we could observe incorrect fixes, but we could not attribute the sample to one of these problems (column 7). These results also show that as opposed to heuristic data cleaning applied in prior works such as TFix [4] that worked on simple issues and Lint warnings, the more complex static analysis reports would also need more manual labeling effort to take into account the complexities in the input data. Based on this finding, we designed our data collection pipeline accordingly and manually labelled the candidate file pairs in a web-application we developed.

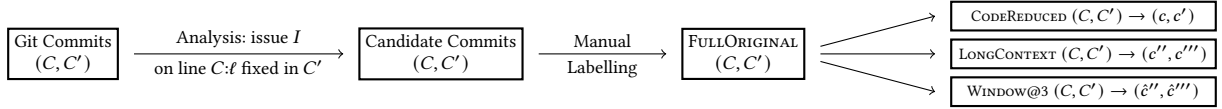
Data Collection & Cleaning. We created data according to the pipeline shown in Fig. 5: For each pair of pre-/post-commit source files (C, C') we ran the static analysis and collected the candidate file pairs where a certain issue I present on line ℓ in C was not reported anymore in C' . Then, we manually labelled candidate samples as negative and positive with respect to making a proper code change fixing the issue. We call the output of such a process a *fix pair*. On the cleaned fix pairs, we applied CODEREDUCE for the issue (C, ℓ, I) . This step's output, apart from yielding the reduced pre-commit code c , allows obtaining a *reduced version* c' of the post-commit, thus resulting in the reduced pair (c, c') . We generate final data in several flavours: FULLORIGINAL, CODEREDUCED, LONGCONTEXT, and WINDOW@3. Below we give explanations and the motivation behind each flavour.

FULLORIGINAL dataset comprises pre-files scraped from GitHub in their entirety. In the post-files, only changes relevant to the fix are retained, excluding irrelevant modifications like style fixes, refactoring, or new features. As highlighted in Section 2, CODEREDUCE is designed to ignore such changes. To ensure a fair experimental setup in comparison to CODEREDUCE, we take precautions to filter noisy changes in this dataset. Without this control, the noisy changes would lead to unfair comparisons in the metrics dependent on direct code comparison and also potentially harm the learning process.

CODEREDUCED data contains the diffs from FULLORIGINAL data passed through the CODEREDUCE algorithm. This results

Table 1. Fix statistics on randomly sampled commits that remove static analysis reports.

1. Issue Category	2. Candidate Commits	3. Good Fix	4. Deletion/ Refactor	5. Accidental Fix	6. Precision Loss	7. Other
AST	106 386	38%	56%	6%	0%	0%
LOCAL	154 945	26%	56%	12%	4%	2%
FILEWIDE	35 206	36%	32%	24%	4%	4%
SECURITYLOCAL	26 499	18%	70%	8%	4%	0%
SECURITYFLOW	58 523	4%	78%	8%	10%	0%

**Figure 5.** Overview of the data pipeline. See the main body for a detailed explanation of the steps.**Table 2.** Data statistics, including token size percentiles. Tokenization was performed using the tokenizer of StarCoderBase [25] model. Note that CODEREDUCE makes data suitable even for feeding into transformers with short attention range.

Dataset	# Datapoints		Token Size @ p -Percentile				
	Train	Test	$p = 25$	$p = 50$	$p = 75$	$p = 95$	$p = 99$
FULLORIGINAL			438	878	1794	6090	16947
CODEREDUCED	3532	1818	46	79	135	322	787
WINDOW@3			44	56	73	109	152
LONGCONTEXT			396	578	768	1036	1332

Table 3. CODEREDUCE’s compression ratio for $\{\text{FULLORIGINAL} \mapsto \text{CODEREDUCED}\}$.

Issue Category	Compression ratio (token size)	
	Train	Test
AST	$\times 40.67$	$\times 57.44$
LOCAL	$\times 28.78$	$\times 22.44$
SECURITYLOCAL	$\times 22.86$	$\times 23.60$
FILEWIDE	$\times 19.83$	$\times 10.96$
SECURITYFLOW	$\times 19.46$	$\times 20.80$

in a much smaller-sized source code which, importantly, does not contain parts unrelated to the issue at hand.

LONGCONTEXT data is a result of keeping ± 50 lines of code around the line of the detected issue and its corresponding fix. This type of data serves for experimenting with baseline models.

WINDOW@3 data is a result of keeping ± 3 lines of code around the line of the detected issue and its corresponding fix. This type of data also serves for experimenting with baseline models.

Dataset statistics are provided in Table 2. We also quantify the ratio between token lengths of the FULLORIGINAL and CODEREDUCED source code in Table 3.

5 Experimental Evaluation

We present an extensive evaluation of DEEPCODE AI FIX.

5.1 Train/Test Split

In many domains, the conventional approach involves randomly partitioning the dataset into training and test sets. However, this methodology, commonly employed in program repair research, is inherently unsuitable for the field of automated program repair. Randomly splitting the data may inadvertently lead to instances from the same repository or even the file being allocated to both the training and test sets, resulting in data leakage. Furthermore, the use of pretrained models introduces another potential source of data leakage. These models have been trained on extensive datasets that encompass open-source code, creating the possibility that samples in the fine-tuning test dataset were also present in the pretraining dataset of the underlying model. Remarkably, these two concerns have not received widespread attention in the context of Automated Program Repair.

We introduce an advanced train/test splitting that effectively addresses both of these issues. In addition to utilizing code with permissive licenses, we conducted data mining from open-source repositories governed by restrictive licenses. These restrictive licenses prohibit the utilization of code for learning but allow its use for testing. Consequently,

we constructed our test set from these repositories. Note that this approach results in the utilization of entirely distinct sets of repositories for training and testing, eliminating the potential for data leakage stemming from shared repositories and files. Moreover, this approach effectively mitigates data leakage arising from the pretrained model’s dataset. Given that the repositories covered by non-permissive licenses were not suitable for training, we can reasonably assume that they were not utilized by prior works either.

Finally, this allows us to have a larger set of test samples as opposed to traditional splits where one is usually concerned with losing training samples. Our test dataset contains 1’818 samples and they were manually labelled in the same way as the training samples.

5.2 Metrics

For measuring models’ performance, we utilize two metrics: functional correctness (PASS@ k) and exact match to the target code (EXACTMATCH@ k). Both metrics are computed using “@ k ” flavor, that is, at different amounts of predictions generated by beam search [15] or nucleus sampling [19] depending on the model. To simplify the explanation, we consider the following notation: for input code C with an issue I instance detected on line ℓ , the model generates k outputs $\mathbf{p} \equiv \mathbf{p}(C, \ell, I) = (p_1, \dots, p_k)$.

PASS@ k : The code analysis engine is capable, for the given issue instance (C, ℓ, I) and a corresponding prediction p , to provide a predicate $\text{DoesFix}(p, C, \ell, I)$, capturing if this prediction fixes the given issue instance. Note that line information is important, because there can be multiple instances of the same issue on several lines. In addition to that and following the common practice (e.g. see [4]), another predicate $\text{NoNewIssues}(p|C)$ can check if p introduced new issues elsewhere in the code compared to C . Using this information, the PASS@ k checks if any of the k predictions fixed the static analysis report *and* not introduced any new issues, and takes the average:

$$\text{PASS@}k = \frac{1}{|\{(C, \ell, I)\}|} \sum_{(C, \ell, I)} \max_{p \in \mathbf{p}} [\text{DoesFix}(p, C, \ell, I) \wedge \text{NoNewIssues}(p|C)]. \quad (1)$$

Naturally, $\text{DoesFix}(\dots)$ and $\text{NoNewIssues}(\dots)$ require that the prediction is parseable and syntactically correct code.

EXACTMATCH@ k : This metric relies on the existence of the labeled target fix C' for the given issue instance (C, ℓ, I) and computes if any of the predictions equals the labeled target code C' :

$$\text{EXACTMATCH@}k = \frac{1}{|\{(C, C', \ell, I)\}|} \sum_{(C, C', \ell, I)} \max_{p \in \mathbf{p}} [p = C'] \quad (2)$$

Both metrics have their advantages and disadvantages. The quality of PASS@ k depends on the robustness of the analysis engine. For example, a trivial definition of $\text{DoesFix}(\dots)$

as “the issue is not detected anymore” can be easily overfitted to — e.g., by deleting the whole code. While the code analysis engine used in our experiments is much more advanced, it is not free of producing false positive in certain corner cases. Defining a “suitable” metric for program repair proved to be hard. Reporting functional correctness and exact match has the advantage of relaying the trade-off between “creativity” and “canonicalization” of fixes, with PASS@ k and EXACTMATCH@ k being the upper- and lower-bound for some “true” metric.

5.3 Training and Inference Configuration

Open-source models (StarCoderBase, T5, Mistral, Mixtral): We fine-tuned them on 16 Nvidia A100 GPUs for 60 epochs with batch size of 4 per device, gradient accumulation steps of 16, learning rate of 10^{-5} with linear scheduler and warm-up ratio of 0.1. We use DeepSpeed [42] with ZeRO-3 optimization [41]. We use beam search and report various “@ k ” metrics. Specifically for Mixtral, we used QLoRA [8] to effectively fine-tune it as the model is relatively large.

Models accessible via API (GPT-3.5, GPT-4): GPT-3.5 [35] and GPT-4 [36] allow querying via APIs. We employed the most recent releases, namely *gpt-3.5-turbo-0613* and *gpt-4-0613*, as of November 2023. We accessed the models via APIs, and ran the inference on our test set with few-shot learning.

Few-shot examples choice: for each of the samples requesting to fix an issue I , the few-shot training examples were chosen randomly from the training dataset for the same issue type. For each query, we provided 1 and 2 few-shot example(s) for GPT-3.5 and GPT-4, respectively. This choice was made based on the context window limitations of each model. Seeds were preserved to keep few-shot examples consistent across experiments.

Prompt structure: we used the best practices [31] issued for GPT-3.5 and GPT-4 by OpenAI to set up the prompt and the conversations. For more in-depth details on the shape and structure of the prompts used, see Appendix B.

Inference hyperparameters: We set the maximum number of generated tokens to the maximum context size of the model and used temperature of 0.2 for cases where we generate multiple predictions. While querying GPT-4 with full file in a zero-shot setting, the temperature was 0. The instructions we provided in the system prompt (see Appendix B) were sufficient to configure the model’s output.

5.4 Comparison with Baselines

In the following main experiment, we aimed to compare bug-fixing performance of different models under different context extraction methods and learning setups, including models like GPT-4 — thus forming strong baselines to test our approach. We use text-to-text transformers pre-trained on code or natural language (StarCoderBase [25], T5 [40], Mixtral [22]) or for few-shot learning via API (GPT-3.5 [35], GPT-4 [36]). Further, we utilize three datasets, CODEREDUCED

Table 4. Evaluation of PASS@ k and EXACTMATCH@ k metrics for models that use CODEREDUCE (marked as $\ddagger$) against baselines of TFix [4], and various large-context models. Model(s) corresponding to our approach is marked as $\ddagger$. Refer to Section 5.4 for discussion. For examples of fixes produced by DEEPCODE AI FIX, see Appendix C.

Issue Category	Model	PASS@ k (%)			EXACTMATCH@ k (%)		
		$k = 1$	$k = 3$	$k = 5$	$k = 1$	$k = 3$	$k = 5$
AST	MIXTRAL-8x7B-CODEREDUCED $\ddagger$	81.01	88.96	89.16	39.29	52.25*	53.5*
	STARCODER-7B-CODEREDUCED $\ddagger$	70.05	80.84	82.31	41.19	48.15	48.56
	STARCODER-7B-LONGCONTEXT	17.74	18.21	19.3	16.93	18.04	18.04
	T5-WINDOW@3 (TFix)	41.24	59.61	64.73	33.98	37.61	38.14
	GPT-3.5-CODEREDUCED-ONESHOT $\ddagger$	80.47	80.95	81.75	36.8	39.38	39.98
	GPT-3.5-LONGCONTEXT-ONESHOT	49.13	55.27	57.71	25.99	27.98	31.02
	GPT-4-CODEREDUCED-TWOSHOT $\ddagger$	89.12	89.72*	89.72*	43.43	43.48	43.48
	GPT-4-LONGCONTEXT-TWOSHOT	83.86	84.13	84.52	43.48*	47.27	47.7
	GPT-4-32K-CODEREDUCED-ZEROSHOT $\ddagger$	90.29*	—	—	40.67	—	—
	GPT-4-32K-FULLORIGINAL-ZEROSHOT	88.74	—	—	38.40	—	—
LOCAL	MIXTRAL-8x7B-CODEREDUCED $\ddagger$	69.77	90.19*	92.71*	31.37	41.77	44.11
	STARCODER-7B-CODEREDUCED $\ddagger$	82.75	89.72	90.19	34.23	42.02	42.73
	STARCODER-7B-LONGCONTEXT	28.9	36.82	39.43	18.35	24.5	24.77
	T5-WINDOW@3 (TFix)	39.95	61.74	71.76	24.91	32.25	32.72
	GPT-3.5-CODEREDUCED-ONESHOT $\ddagger$	79.66	81.75	81.75	25.67	25.82	25.95
	GPT-3.5-LONGCONTEXT-ONESHOT	61.78	67.49	69.8	26.46	28.9	30.64
	GPT-4-CODEREDUCED-TWOSHOT $\ddagger$	88.55	89.12	89.16	37.05	37.64	37.79
	GPT-4-LONGCONTEXT-TWOSHOT	83.51	87.16	87.32	44.05*	44.42*	44.42*
	GPT-4-32K-CODEREDUCED-ZEROSHOT $\ddagger$	93.77*	—	—	28.36	—	—
	GPT-4-32K-FULLORIGINAL-ZEROSHOT	81.50	—	—	25.64	—	—
FILEWIDE	MIXTRAL-8x7B-CODEREDUCED $\ddagger$	50.37	67.61	85.66*	41.66	47.91	48.95
	STARCODER-7B-CODEREDUCED $\ddagger$	77.38	80.16	85.02	44.59*	54.5*	54.5*
	STARCODER-7B-LONGCONTEXT	20.02	25.16	25.85	11.01	12.0	13.04
	T5-WINDOW@3 (TFix)	24.29	51.84	54.27	18.9	20.98	20.98
	GPT-3.5-CODEREDUCED-ONESHOT $\ddagger$	71.13	75.3	75.3	31.88	36.74	36.74
	GPT-3.5-LONGCONTEXT-ONESHOT	61.32	65.49	66.18	20.98	25.15	25.15
	GPT-4-CODEREDUCED-TWOSHOT $\ddagger$	84.05*	84.05	84.05	37.75	37.75	38.04
	GPT-4-LONGCONTEXT-TWOSHOT	76.18	76.18	76.18	30.98	30.98	30.98
	GPT-4-32K-CODEREDUCED-ZEROSHOT $\ddagger$	84.38*	—	—	37.74	—	—
	GPT-4-32K-FULLORIGINAL-ZEROSHOT	79.91	—	—	24.04	—	—
SECURITYLOCAL	MIXTRAL-8x7B-CODEREDUCED $\ddagger$	63.58	92.2*	94.41*	15.77	23.46	25.99
	STARCODER-7B-CODEREDUCED $\ddagger$	74.68	89.08	91.76	20.18*	29.53*	32.23*
	STARCODER-7B-LONGCONTEXT	22.24	30.88	31.61	8.14	9.69	10.66
	T5-WINDOW@3 (TFix)	43.03	76.44	80.57	10.83	19.99	21.42
	GPT-3.5-CODEREDUCED-ONESHOT $\ddagger$	81.35	84.03	85.56	11.44	11.58	11.66
	GPT-3.5-LONGCONTEXT-ONESHOT	68.22	73.76	74.3	7.59	8.04	8.25
	GPT-4-CODEREDUCED-TWOSHOT $\ddagger$	86.6*	87.0	87.05	13.61	14.27	14.27
	GPT-4-LONGCONTEXT-TWOSHOT	78.7	84.96	85.2	11.17	11.91	12.12
	GPT-4-32K-CODEREDUCED-ZEROSHOT $\ddagger$	84.24	—	—	8.98	—	—
	GPT-4-32K-FULLORIGINAL-ZEROSHOT	82.85	—	—	6.25	—	—
SECURITYFLOW	MIXTRAL-8x7B-CODEREDUCED $\ddagger$	41.93	72.97	81.62*	9.26	17.9*	20.27*
	STARCODER-7B-CODEREDUCED $\ddagger$	49.15	65.9	68.53	10.63*	13.49	15.7
	STARCODER-7B-LONGCONTEXT	5.19	8.93	10.01	7.14	7.57	7.83
	T5-WINDOW@3 (TFix)	15.12	48.8	54.15	8.18	9.92	10.15
	GPT-3.5-CODEREDUCED-ONESHOT $\ddagger$	51.71	57.15	58.66	2.47	2.66	2.72
	GPT-3.5-LONGCONTEXT-ONESHOT	17.17	20.22	20.74	5.5	5.71	5.71
	GPT-4-CODEREDUCED-TWOSHOT $\ddagger$	74.74*	77.04*	79.71	3.18	3.31	3.41
	GPT-4-LONGCONTEXT-TWOSHOT	51.62	55.77	59.74	6.58	7.09	7.32
	GPT-4-32K-CODEREDUCED-ZEROSHOT $\ddagger$	64.71	—	—	1.84	—	—
	GPT-4-32K-FULLORIGINAL-ZEROSHOT	50.12	—	—	0.85	—	—

(represents our approach to context extraction) LONGCONTEXT (represents long context) and WINDOW@3 (represents a baseline, see e.g. [4]). As a result, the following models were evaluated:

StarCoderBase: StarCoderBase model [25], fine-tuned by us on the CODEREDUCED data LONGCONTEXT, allowing us to compare both approaches against each other in a fine-tuning setup.

TFix [4] (also named T5-WINDOW@3 for clarity): T5 model fine-tuned by us on the WINDOW@3 data, i.e. only 3 lines before/after the issue are taken as the input to the model. Thus, the model only utilizes linear span of context lines to be trained on.

GPT-3.5 & GPT-4: Predictions for the CODEREDUCED, LONGCONTEXT and FULLORIGINAL are obtained via few-shot learning from the model.

Mixtral-8x7B: Predictions for the CODEREDUCED are obtained via fine-tuning with QLoRA. Due to the model size and limited resources, we could not fine-tune this model on LONGCONTEXT, which would strengthen our results.

Metrics on CODEREDUCED: During inference, after obtaining predictions, they are merged back into the full source code by means of the MERGEBACK algorithm, thus resulting in predicting the complete file. The metrics are then computed on the full files.

Metrics on LONGCONTEXT & WINDOW@3: During inference, after obtaining such “windowed” predictions, they are pasted back into the full source code, and then the metrics are computed on the full files.

Results are summarized in Table 8. We can observe that our approaches take advantage of “compressing” the context through reduction: they outperform the LONGCONTEXT, FULLORIGINAL and WINDOW@3 baselines by a considerable margin w.r.t. the PASS@ k and EXACTMATCH@ k .

For the GPT model family, within each pair of CODEREDUCED-LONGCONTEXT and CODEREDUCED-FULLORIGINAL, the former leads to better PASS@ k . The gap is especially large for issue categories with complex data flow. For GPT-4 and SECURITYFLOW, CODEREDUCE improves 23% over LONGCONTEXT, while improving 14% over FULLORIGINAL. We also see that GPT-4-32K-FULLORIGINAL-ZEROSHOT yields not better, but competitive performance in some categories but querying the model in this way has a considerable latency. Hence, we evaluated it only for $k = 1$. To be fair, we also evaluated GPT-4-CODEREDUCED-ZEROSHOT with $k = 1$ and our approach yields better results in all categories, especially for SECURITYFLOW, FILEWIDE and LOCAL.

We note that there is a range of other bugfixing models such as SequenceR [7], CoCoNuT [27] or Hoppity [10] that were already shown to be noncompetitive to the T5 model used in TFix by prior works ([13], [4]). We omit them from our evaluation as our approach already outperforms TFix by a large margin. We also investigated the potential effects of model size between 1B and 7B and model architecture

between STARCORDERBASE and MISTRAL [21]. The results are summarized in Appendix D. In contrast to the findings observed by [4], we conclude that increasing model size lead to significant and consistent advantages. Also, the pre-trained model and its architecture can make a significant difference. Finally, examples of the model predictions, fixing long-ranging issues that benefit from using CODEREDUCE, can be found in Appendix C.

5.5 Effects of MERGEBACK

Compared to long context or window-based baselines, our approach using CODEREDUCED contains more non-trivial steps, including MERGEBACK. In Table 5 we assess the effect of MERGEBACK on metrics. Note that this is possible because these PASS@ k /EXACTMATCH@ k are computable also on reduced (before MERGEBACK) code, because one can validate if the fix removes a static analysis report on reduced code.

One can observe that the MERGEBACK algorithm is not perfect in the sense that, compared to evaluating reduced predictions, it introduced a certain drop of PASS@ k , while EXACTMATCH@ k does not suffer. One of the reasons is that as the model performs more “creative” fixes, not all of them are possible to integrate back in the original large code. It should be noted that the performance of our approach can be further increased by improving the MERGEBACK algorithm. We leave tightening this gap as future work.

5.6 Latency of the end-to-end bugfixing system

We performed an experiment to compare the algorithm of CODEREDUCE (Algorithm 1) with a vanilla HDD algorithm [32]. To avoid differences caused by the machine and analyzer speeds, we evaluate the number of calls to the analyzer made by code reduction algorithms. For this evaluation, we took 1024 programs from our training dataset and measured the code reduction speed using both settings. The number of program analyzer calls executed by Algorithm 1 averages to 9.44 and has geometric mean of 4.99, whereas the number of calls to the program analyzer the HDD algorithm performs averages to 11.52 and has geometric mean of 7.25. When taking into account geometric means that are useful for computing ratios, it leads to a ratio of 0.68 steps for the improved algorithm versus HDD or 30% reduction. When comparing averages, the reduction is 20%, due to several outlier samples. The most complex example in our data required 181 calls to the analyzer.

We performed the evaluation on an AWS c5ad.8xlarge instance, running Ubuntu 22.04. In terms of latency, each call to the underlying static analyzer takes around 70 to 80ms. This means the entire CODEREDUCE algorithm takes less than 1 second on average. Querying STARCORDERBASE-7B takes on average 605ms per prediction with an A100 GPU. Taking into account the need to check the solution after MERGEBACK and generating several candidates from the language model,

Table 5. Influence of MERGEBACK on the metrics for STARCODERBASE-CODEREDUCED. Metrics are calculated on the full source code and reduced code, respectively.

Issue Category	Step	PASS@ k (%)		EXACTMATCH@ k (%)	
		$k = 1$	$k = 3$	$k = 1$	$k = 3$
AST	after MERGEBACK	70.05	80.84	41.19	48.15
	before MERGEBACK	78.97	88.63	41.19	48.15
LOCAL	after MERGEBACK	82.75	89.72	34.23	42.02
	before MERGEBACK	81.60	90.85	34.29	42.02
FILEWIDE	after MERGEBACK	77.38	80.16	44.59	54.50
	before MERGEBACK	87.62	92.06	44.59	54.50
SECURITYLOCAL	after MERGEBACK	74.68	89.08	20.18	29.53
	before MERGEBACK	79.20	93.21	20.18	29.53
SECURITYFLOW	after MERGEBACK	49.15	65.90	10.63	13.49
	before MERGEBACK	52.40	69.26	10.63	13.49

the proposed bugfixing system performs predictions within a few seconds and is usable in an IDE setting.

6 Related Work

Automated program repair (APR) has been studied both from traditional software engineering and machine learning perspectives [14, 33]. Traditional approaches typically require test cases, crash reports or other specifications. Given a program violating the expected behaviour, APR systems output a correct program fulfilling the expected behaviour, usually by performing a smart search over the space of program modifications. However, most of these works end up being unpractical due to the enormous search space, continuous recompilation of candidate patches, and re-execution of the tests [20]. Some works try to synthesize the output by solving symbolic constraints [29, 34, 55] or applying learned edit patterns on abstract syntax trees [3, 12, 26]. Both approaches typically suffer from not generalizing as the behaviour is specific to individual programs [48] or suffer from overfitting [56]. Our work significantly differs from prior APR approaches both technically and usability. DEEPCODE AI FIX generalizes across different programs by learning from a large dataset of diverse bugs and fixes, scales to larger edits and generates fixes practically instantly in comparison to APR works.

Recent years have seen an increase in learning-based tools. A major hurdle for these systems is the lack of training data. Several works attack this problem by generating synthetic fixes for specific types of bugs like incorrect operators, variable misuses [9, 39]. Applying various models such as LSTMs [52] and Transformers [18] increase the accuracy on the synthetic datasets, but these tools still produce mostly false positives on real-world bug distributions [2]. As a result, these systems have limited practical applicability and the problem of the distribution shift by learning from synthetic data remains an open research question [17]. Other recent

works use large language models to transform programs with errors into programs without errors [4, 16]. Another line of work [24, 38] proposes to replace fine-tuning the model with selecting several training data samples similar to the query and using them as a prompt in a few-shot prediction of a larger pretrained model for code [6]. All of these works are limited to relatively small programs that fit into the context size of the model they use.

7 Conclusion

We presented a new learning-based system, DEEPCODE AI FIX, for automatically fixing non-trivial coding errors and security vulnerabilities. The key insight is to rely on a code reduction mechanism that incorporates program analysis into the machine learning pipeline. DEEPCODE AI FIX learns to fix non-trivial coding errors accurately as CODEREDUCE extracts the essential information needed for the fix, allowing the learning process to avoid having to uncover arbitrarily long-range dependencies and focusing it on attending to the crucial parts of code.

Our analysis of open-source commits reveals insights about the difficulty of collecting large amounts of data for program repair. As a solution, we built a high-quality dataset bugs and fixes extracted from millions of real-world GitHub commits.

We evaluated our approach on multiple models - StarCoderBase, Mixtral, T5, GPT-3.5 and GPT-4 and demonstrated that directly using a model which tries to learn the complex long-range dependencies needed to produce a correct fix, performs generally worse than using a context extracted by CODEREDUCE. Overall, DEEPCODE AI FIX outperformed the previous state-of-the-art baseline TFix and helped multiple models in different setups to perform better as it utilizes program analysis to deal with long-range dependencies and data flows, greatly simplifying the attention learning task.

Although this paper’s focus is on program repair, we believe our work is an important step in incorporating program analysis into machine learning and clearly highlights the need for code analysis, even when using powerful LLMs.

References

- [1] Miltiadis Allamanis, Marc Brockschmidt, and Mahmoud Khademi. 2018. Learning to Represent Programs with Graphs. In *ICLR 2018*.
- [2] Miltiadis Allamanis, Henry Jackson-Flux, and Marc Brockschmidt. 2021. Self-Supervised Bug Detection and Repair. In *NeurIPS 2021, virtual*. 27865–27876.
- [3] Johannes Bader, Andrew Scott, Michael Pradel, and Satish Chandra. 2019. Getafix: learning to fix bugs automatically. *Proc. ACM Program. Lang.* 3, OOPSLA (2019), 159:1–159:27.
- [4] Berkay Berabi, Jingxuan He, Veselin Raychev, and Martin T. Vechev. 2021. TFix: Learning to Fix Coding Errors with a Text-to-Text Transformer. In *ICML 2021, virtual (Proceedings of Machine Learning Research, Vol. 139)*. PMLR, 780–791.
- [5] Al Bessey, Ken Block, Ben Chelf, Andy Chou, Bryan Fulton, Seth Hallem, Charles Henri-Gros, Asya Kamsky, Scott McPeak, and Dawson Engler. 2010. A Few Billion Lines of Code Later: Using Static Analysis to Find Bugs in the Real World. *Commun. ACM* 53, 2 (feb 2010), 66–75.
- [6] Mark Chen, Jerry Tworek, Heewoo Jun, Qiming Yuan, Henrique Ponde de Oliveira Pinto, Jared Kaplan, Harri Edwards, Yuri Burda, Nicholas Joseph, Greg Brockman, Alex Ray, Raul Puri, Gretchen Krueger, Michael Petrov, Heidy Khlaaf, Girish Sastry, Pamela Mishkin, Brooke Chan, Scott Gray, Nick Ryder, Mikhail Pavlov, Alethea Power, Lukasz Kaiser, Mohammad Bavarian, Clemens Winter, Philippe Tillet, Felipe Petroski Such, Dave Cummings, Matthias Plappert, Fotios Chantzis, Elizabeth Barnes, Ariel Herbert-Voss, William Hebgén Guss, Alex Nichol, Alex Paino, Nikolas Tezak, Jie Tang, Igor Babuschkin, Suchir Balaji, Shantanu Jain, William Saunders, Christopher Hesse, Andrew N. Carr, Jan Leike, Josh Achiam, Vedant Misra, Evan Morikawa, Alec Radford, Matthew Knight, Miles Brundage, Mira Murati, Katie Mayer, Peter Welinder, Bob McGrew, Dario Amodei, Sam McCandlish, Ilya Sutskever, and Wojciech Zaremba. 2021. Evaluating Large Language Models Trained on Code.
- [7] Zimin Chen, Steve James Kommrusch, Michele Tufano, Louis-Noël Pouchet, Denys Poshyvanyk, and Martin Monperrus. 2019. Sequencer: Sequence-to-sequence learning for end-to-end program repair. *IEEE Transactions on Software Engineering* (2019).
- [8] Tim Dettmers, Artidoro Pagnoni, Ari Holtzman, and Luke Zettlemoyer. 2023. QLoRA: Efficient Finetuning of Quantized LLMs. *CoRR abs/2305.14314* (2023). <https://doi.org/10.48550/ARXIV.2305.14314> arXiv:2305.14314
- [9] Jacob Devlin, Jonathan Uesato, Rishabh Singh, and Pushmeet Kohli. 2018. Semantic Code Repair using Neuro-Symbolic Transformation Networks. Workshop track invitation, ICML 2018. <https://openreview.net/forum?id=r1hsjCe0Z>
- [10] Elizabeth Dinella, Hanjun Dai, Ziyang Li, Mayur Naik, Le Song, and Ke Wang. 2020. Hoppity: Learning Graph Transformations to Detect and Fix Bugs in Programs. In *ICLR*. <https://openreview.net/forum?id=SJeqs6EFvB>
- [11] ESLint. 2022. ESLint rules. <https://eslint.org/docs/latest/rules/>
- [12] Khashayar Etemadi, Nicolas Harray, Simon Larsén, Haris Adzémovic, Henry Luong Phu, Ashutosh Verma, Fernanda Madeiral, Douglas Wikström, and Martin Monperrus. 2021. Sorald: Automatic Patch Suggestions for SonarQube Static Analysis Violations. *CoRR abs/2103.12033* (2021). arXiv:2103.12033 <https://arxiv.org/abs/2103.12033>
- [13] Michael Fu, Van Nguyen, Chakkrit Tantithamthavorn, Dinh Phung, and Trung Le. 2023. Vision Transformer-Inspired Automated Vulnerability Repair. *ACM Trans. Softw. Eng. Methodol.* (nov 2023). <https://doi.org/10.1145/3632746> Just Accepted.
- [14] Luca Gazzola, Daniela Micucci, and Leonardo Mariani. 2019. Automatic Software Repair: A Survey. *IEEE Trans. Software Eng.* 45, 1 (2019), 34–67.
- [15] Alex Graves. 2012. Sequence Transduction with Recurrent Neural Networks. In *ICML 2012, Workshop on Representation Learning*.
- [16] Rahul Gupta, Soham Pal, Aditya Kanade, and Shirish Shevade. 2017. DeepFix: Fixing Common C Language Errors by Deep Learning. *AAAI Conference on Artificial Intelligence* 31, 1 (Feb. 2017). <https://ojs.aaai.org/index.php/AAAI/article/view/10742>
- [17] Jingxuan He, Luca Beurer-Kellner, and Martin T. Vechev. 2022. On Distribution Shift in Learning-based Bug Detectors. In *ICML 2022 (Proceedings of Machine Learning Research, Vol. 162)*. PMLR, 8559–8580.
- [18] Vincent J. Hellendoorn, Charles Sutton, Rishabh Singh, Petros Maniatis, and David Bieber. 2020. Global Relational Models of Source Code. In *ICLR 2020*. <https://openreview.net/forum?id=B1lnbRNtWr>
- [19] Ari Holtzman, Jan Buys, Li Du, Maxwell Forbes, and Yejin Choi. 2020. The Curious Case of Neural Text Degeneration. In *8th International Conference on Learning Representations, ICLR 2020, Addis Ababa, Ethiopia, April 26–30, 2020*. OpenReview.net. <https://openreview.net/forum?id=rygGQYrFvH>
- [20] Jinru Hua, Mengshi Zhang, Kaiyuan Wang, and Sarfraz Khurshid. 2018. Towards Practical Program Repair with On-Demand Candidate Generation. In *ICSE 2018*. ACM, 12–23.
- [21] Albert Q. Jiang, Alexandre Sablayrolles, Arthur Mensch, Chris Bamford, Devendra Singh Chaplot, Diego de Las Casas, Florian Bressand, Gianna Lengyel, Guillaume Lample, Lucile Saulnier, Léo Renard Lavaud, Marie-Anne Lachaux, Pierre Stock, Teven Le Scao, Thibaut Lavril, Thomas Wang, Timothée Lacroix, and William El Sayed. 2023. Mistral 7B. *CoRR abs/2310.06825* (2023). <https://doi.org/10.48550/ARXIV.2310.06825> arXiv:2310.06825
- [22] Albert Q. Jiang, Alexandre Sablayrolles, Antoine Roux, Arthur Mensch, Blanche Savary, Chris Bamford, Devendra Singh Chaplot, Diego de Las Casas, Emma Bou Hanna, Florian Bressand, Gianna Lengyel, Guillaume Bour, Guillaume Lample, Léo Renard Lavaud, Lucile Saulnier, Marie-Anne Lachaux, Pierre Stock, Sandeep Subramanian, Sophia Yang, Szymon Antoniak, Teven Le Scao, Théophile Gervet, Thibaut Lavril, Thomas Wang, Timothée Lacroix, and William El Sayed. 2024. Mixtral of Experts. *CoRR abs/2401.04088* (2024). <https://doi.org/10.48550/ARXIV.2401.04088> arXiv:2401.04088
- [23] Yanjie Jiang, Hui Liu, Xiaoqing Luo, Zhihao Zhu, Xiaye Chi, Nan Niu, Yuxia Zhang, Yamin Hu, Pan Bian, and Lu Zhang. 2022. BugBuilder: An Automated Approach to Building Bug Repository. *IEEE Transactions on Software Engineering* (2022), 1–1. <https://doi.org/10.1109/TSE.2022.3177713>
- [24] Harshit Joshi, José Pablo Cambronero Sánchez, Sumit Gulwani, Vu Le, Ivan Radicek, and Gust Verbruggen. 2022. Repair Is Nearly Generation: Multilingual Program Repair with LLMs. *CoRR abs/2208.11640* (2022). <https://doi.org/10.48550/arXiv.2208.11640> arXiv:2208.11640
- [25] Raymond Li, Loubna Ben Allal, Yangtian Zi, Niklas Muennighoff, Denis Kocetkov, Chenghao Mou, Marc Marone, Christopher Akiki, Jia Li, Jenny Chim, Qian Liu, Evgenii Zheltonozhskii, Terry Yue Zhuo, Thomas Wang, Olivier Dehaene, Mishig Davaadorj, Joel Lamy-Poirier, João Monteiro, Olek Shliazhko, Nicolas Gontier, Nicholas Meade, Armel Zebaze, Ming-Ho Yee, Logesh Kumar Umapathi, Jian Zhu, Benjamin Lipkin, Muhtasham Oblokulov, Zhiruo Wang, Rudra Murthy V, Jason Stillerman, Siva Sankalp Patel, Dmitry Abulkhanov, Marco Zocca, Manan Dey, Zhihan Zhang, Nour Moustafa-Fahmy, Urvashi Bhat-tacharyya, Wenhao Yu, Swayam Singh, Sasha Luccioni, Paulo Villegas, Maxim Kunakov, Fedor Zhdanov, Manuel Romero, Tony Lee, Nadav Timor, Jennifer Ding, Claire Schlesinger, Hailey Schoelkopf, Jan Ebert, Tri Dao, Mayank Mishra, Alex Gu, Jennifer Robinson, Carolyn Jane Anderson, Brendan Dolan-Gavitt, Danish Contractor, Siva Reddy, Daniel Fried, Dzmitry Bahdanau, Yacine Jernite, Carlos Muñoz Ferrandis, Sean Hughes, Thomas Wolf, Arjun Guha, Leandro von Werra, and

- Harm de Vries. 2023. StarCoder: may the source be with you! *CoRR* abs/2305.06161 (2023). <https://doi.org/10.48550/ARXIV.2305.06161> arXiv:2305.06161
- [26] Fan Long, Peter Amidon, and Martin C. Rinard. 2017. Automatic inference of code transforms for patch generation. In *Foundations of Software Engineering, ESEC/FSE 2017*. ACM, 727–739.
- [27] Thibaud Lutellier, Lawrence Pang, Hung Viet Pham, Moshi Wei, and Lin Tan. 2019. ENCORE: Ensemble Learning using Convolution Neural Machine Translation for Automatic Program Repair. *CoRR* abs/1906.08691 (2019). <http://arxiv.org/abs/1906.08691>
- [28] Alexandru Marginean, Johannes Bader, Satish Chandra, Mark Harman, Yue Jia, Ke Mao, Alexander Mols, and A. Scott. 2019. SapFix: automated end-to-end repair at scale. In *ICSE 2019*.
- [29] Sergey Mechtaev, Jooyong Yi, and Abhik Roychoudhury. 2016. Angelix: scalable multiline program patch synthesis via symbolic analysis. In *ICSE 2016*.
- [30] Microsoft. 2023. Introducing AI-powered application security testing with GitHub Advanced Security. <https://github.blog/2023-11-08-ai-powered-appsec/>
- [31] Microsoft. 2023. *Learn how to work with the ChatGPT and GPT-4 models*. <https://learn.microsoft.com/en-us/azure/cognitive-services/openai/how-to/chatgpt?pivot=programming-language-chat-completions>
- [32] Ghassan Mishserghi and Zhendong Su. 2006. HDD: hierarchical Delta Debugging. In *ICSE 2006*. ACM, 142–151.
- [33] Martin Monperrus. 2018. *The Living Review on Automated Program Repair*. Technical Report HAL-01956501. <https://hal.archives-ouvertes.fr/hal-01956501v2/file/repair-living-review.pdf>
- [34] Hoang Duong Thien Nguyen, Dawei Qi, Abhik Roychoudhury, and Satish Chandra. 2013. SemFix: program repair via semantic analysis. In *ICSE 2013*.
- [35] OpenAI. 2022. *GPT-3.5 Model Registry*. <https://platform.openai.com/docs/model-index-for-researchers/models-referred-to-as-gpt-3-5>
- [36] OpenAI. 2023. GPT-4 Technical Report. *CoRR* abs/2303.08774 (2023). <https://doi.org/10.48550/ARXIV.2303.08774> arXiv:2303.08774
- [37] OWASP Foundation. 2010. *Path Traversal vulnerability description*. https://owasp.org/www-community/attacks/Path_Traversal
- [38] Gabriel Poesia, Alex Polozov, Vu Le, Ashish Tiwari, Gustavo Soares, Christopher Meek, and Sumit Gulwani. 2022. Synchromesh: Reliable Code Generation from Pre-trained Language Models. In *ICLR 2022*.
- [39] Michael Pradel and Koushik Sen. 2018. DeepBugs: a learning approach to name-based bug detection. *Proc. ACM Program. Lang.* 2, OOPSLA (2018), 147:1–147:25.
- [40] Colin Raffel, Noam Shazeer, Adam Roberts, Katherine Lee, Sharan Narang, Michael Matena, Yanqi Zhou, Wei Li, and Peter J. Liu. 2020. Exploring the Limits of Transfer Learning with a Unified Text-to-Text Transformer. *JMLR* 21 (2020), 140:1–140:67.
- [41] Samyam Rajbhandari, Jeff Rasley, Olatunji Ruwase, and Yuxiong He. 2020. ZeRO: Memory Optimizations Toward Training Trillion Parameter Models. ArXiv. <https://www.microsoft.com/en-us/research/publication/zero-memory-optimizations-toward-training-trillion-parameter-models/>
- [42] Jeff Rasley, Samyam Rajbhandari, Olatunji Ruwase, and Yuxiong He. 2020. DeepSpeed: System Optimizations Enable Training Deep Learning Models with Over 100 Billion Parameters. In *SIGKDD 2020 (Virtual Event, CA, USA) (KDD '20)*. ACM, New York, NY, USA, 3505–3506.
- [43] Veselin Raychev, Martin T. Vechev, and Eran Yahav. 2014. Code completion with statistical language models. In *PLDI 2014*. ACM, 419–428.
- [44] John Regehr, Yang Chen, Pascal Cuoq, Eric Eide, Chucky Ellison, and Xuejun Yang. 2012. Test-case reduction for C compiler bugs. In *PLDI 2012*. ACM, 335–346.
- [45] Caitlin Sadowski, Edward Aftandilian, Alex Eagle, Liam Miller-Cushon, and Ciera J. Spain. 2018. Lessons from Building Static Analysis Tools at Google. *Commun. ACM* 61, 4 (mar 2018), 58–66.
- [46] SemGrep. 2023. Autofix. <https://semgrep.dev/docs/writing-rules/autofix/>
- [47] SemGrep. 2023. We put GPT-4 in Semgrep to point out false positives. <https://semgrep.dev/blog/2023/gpt4-and-semgrep-detailed/>
- [48] Edward K. Smith, Earl T. Barr, Claire Le Goues, and Yuriy Brun. 2015. Is the cure worse than the disease? overfitting in automated program repair. In *FSE 2015*. ACM, 532–543.
- [49] Snyk. 2021. SAST tools speed comparison: Snyk Code vs SonarQube and LGTM. <https://snyk.io/blog/sast-tools-speed-comparison-snyk-code-sonarqube-lgtm/>
- [50] Snyk. 2023. Fix code vulnerabilities automatically. <https://docs.snyk.io/scan-using-snyk/snyk-code/exploring-and-working-with-snyk-code-results-in-the-web-ui/fix-code-issues-automatically-with-deepcode-ai-fix-suggestions/>
- [51] Snyk. 2023. Snyk Code - Developer-focused, real-time SAST. <https://snyk.io/product/snyk-code/>
- [52] Marko Vasic, Aditya Kanade, Petros Maniatis, David Bieber, and Rishabh Singh. 2019. Neural Program Repair by Jointly Learning to Localize and Repair. In *ICLR 2019*.
- [53] Veracode. 2023. Veracode Fix. <https://www.veracode.com/fix>
- [54] Yue Wang, Weishi Wang, Shafiq Joty, and Steven C.H. Hoi. 2021. CodeT5: Identifier-aware Unified Pre-trained Encoder-Decoder Models for Code Understanding and Generation. In *EMNLP 2021*. ACL, 8696–8708.
- [55] Jifeng Xuan, Matias Martinez, Favio Demarco, Maxime Clement, Sebastian R. Lamelas Marcote, Thomas Durieux, Daniel Le Berre, and Martin Monperrus. 2017. Nopol: Automatic Repair of Conditional Statement Bugs in Java Programs. *IEEE Trans. Software Eng.* 43 (2017), 34–55.
- [56] He Ye, Matias Martinez, Thomas Durieux, and Martin Monperrus. 2021. A comprehensive study of automatic program repair on the QuixBugs benchmark. *J. Syst. Softw.* 171 (2021).
- [57] Andreas Zeller and Ralf Hildebrandt. 2002. Simplifying and Isolating Failure-Inducing Input. *IEEE Trans. Software Eng.* 28, 2 (2002), 183–200. <https://doi.org/10.1109/32.988498>

A Rule Scope

Table 6. Issues reported by the code analysis, and their respective issue categories. We are actively labeling and enlarging our dataset.

Issue Identifier	Issue Category	# Datapoints	
		Train	Test
AmbiguousConditional	AST	150	58
AngularSceProviderDisabled	AST	2	1
ArgumentsAsParameter	AST	2	3
ArrayConstructor	AST	88	76
AssignmentWithSameVarOnLeftAndRight	AST	8	6
BooleanObjectCreation	AST	31	7
CommaOrSwitch	AST	18	4
ConditionWithAssign	AST	40	15
ContentLengthInCode	AST	2	1
DateMonthDecember	AST	15	6
DuplicateCaseBody	AST	2	1
DuplicateIfBody	AST	2	1
DuplicateObjectProperty	AST	6	1
DuplicateVueProperty	AST	5	1
EmberInitializerDeprecation	AST	4	1
FirefoxImageNonStandard	AST	2	1
FunctionDeclarationInBlock	AST	2	1
HttpToHttps	AST	4	3
MemberExpressionTypo	AST	18	2
NonLocalLoopVar	AST	2	1
ObjectConstructor	AST	35	30
OperatorPrecedence	AST	78	20
ReactApiTypo	AST	80	12
ReactDeprecatedElementProp	AST	2	1
ReactLegacyLifecycleMethod	AST	2	1
ReactMissingArrayKeys	AST	117	42
ReactPropsInGetDefault	AST	2	1
ReactSetInnerHtml	AST	3	2
ReactThisInFunctionComponent	AST	2	1
RedeclarationVars	AST	3	1
RegExpBadCharRange	AST	31	4
RegExpStringInReplace	AST	8	4
RepeatFuncArg	AST	3	2
ShiftOverflow	AST	9	1
SuperDuplicated	AST	7	1
UpdateApi	AST	4	1
UseArrowFunction	AST	3	1
UseGetFullYear	AST	2	1
UseLowercaseTagsForXHTML	AST	8	2
UseStrictWrong	AST	2	1
Utf8Literal	AST	53	6
VarDeclConflict	AST	2	2
Stats for AST: # Issues: 42		859	327
ArrayMethodOnNonArray	LOCAL	4	5

(table continued)

(table continued)

Issue Identifier	Issue Category	# Datapoints	
		Train	Test
AssignToExports	LOCAL	80	8
BadOperandForBitwiseOperation	LOCAL	54	18
BadWrapperObjectCreation	LOCAL	11	2
BitwiseOperationSignChecked	LOCAL	2	1
CallbackShouldReturn	LOCAL	2	1
CollectionArraySizeMatch	LOCAL	19	16
CollectionUpdatedButNeverQueried	LOCAL	2	1
CompareTypeofToString	LOCAL	2	1
ComparisonToNaN	LOCAL	4	2
ConfusedRegex	LOCAL	9	3
ContentTypeNoCharset	LOCAL	2	2
CopyPasteError	LOCAL	3	1
DateMonthIndex	LOCAL	6	1
DeleteOfNonProperty	LOCAL	3	1
DuplicateCaseSwitch	LOCAL	3	1
EqualityMisplacedParentheses	LOCAL	5	1
ExceptionIsNotThrown	LOCAL	4	1
ForEachReturns	LOCAL	2	1
GlobalReplacementRegex	LOCAL	3	1
ImplicitCoercionInOperator	LOCAL	28	4
InOperatorBadLHS	LOCAL	3	1
IncompatibleTypesInComparison	LOCAL	5	1
IncompleteRegex	LOCAL	14	2
IncorrectHtmlEscape	LOCAL	28	9
LoopConditionLengthMissing	LOCAL	63	21
MissingApiCallGet	LOCAL	2	1
MissingApiCallReject	LOCAL	3	1
MissingClose	LOCAL	27	5
MissingCloseOnSomePath	LOCAL	2	1
NoEffectExpression	LOCAL	7	1
NoZeroReturnedInSort	LOCAL	4	1
NonYieldingGenerator	LOCAL	3	1
OverwriteAssignment	LOCAL	2	1
PrimitiveInstanceOf	LOCAL	11	3
PromiseNotCaughtNode	LOCAL	3	1
RHSPrimitiveType	LOCAL	22	13
ReactContextTypes	LOCAL	2	1
ReactForwardPropsToSuper	LOCAL	24	16
ReactIdentifierTypo	LOCAL	41	16
ReactIncorrectReturnValue	LOCAL	6	4
ReactInvalidEventHandlerType	LOCAL	3	1
ReactMissingEventHandlerCleanup	LOCAL	3	2
ReactReservedPropsUsed	LOCAL	4	2
ReactShouldConstructProps	LOCAL	61	25
ReactThisInStaticLifecycleMethod	LOCAL	2	2
ReactWrongStyleProperty	LOCAL	50	40
ReactWrongStyleType	LOCAL	31	42
ReplaceWithSameString	LOCAL	48	35

(table continued)

(table continued)

Issue Identifier	Issue Category	# Datapoints	
		Train	Test
ReplacementRegex	LOCAL	2	1
RequireAsConstructor	LOCAL	3	1
ThisBeforeSuper	LOCAL	31	9
TypeofNotComparedToAnything	LOCAL	5	1
UnusedLoopVar	LOCAL	4	1
UsageOfUninitializedVariable	LOCAL	98	35
UseIsArrayToCheckForArrays	LOCAL	2	2
UseNumberIsNan	LOCAL	3	1
WrongComparisonOperatorInSort	LOCAL	2	1
WrongCsrfTokenHeader	LOCAL	2	1
Stats for LOCAL: # Issues: 59		874	374
BadAwaitExpression	FILEWIDE	14	5
ExpectsObjectDislikesPrimitive	FILEWIDE	2	1
PureFunctionReturnValueIgnored	FILEWIDE	3	1
PureMethodReturnValueIgnored	FILEWIDE	5	2
ReactControlledUncontrolledFormElement	FILEWIDE	29	28
ReactMissingCleanup	FILEWIDE	59	12
ReactModifyState	FILEWIDE	20	8
ReactTypeCreatorUsedAsType	FILEWIDE	38	12
ReactUnusedSnapshot	FILEWIDE	2	1
ReactWrongApiArgumentType	FILEWIDE	2	4
UseInstead	FILEWIDE	7	1
WrongNumberOfArguments	FILEWIDE	3	1
Stats for FILEWIDE: # Issues: 12		184	76
DisablePoweredBy	SECURITYLOCAL	367	142
ElectronInsecureWebPreferences	SECURITYLOCAL	38	48
ElectronLoadInsecureContent	SECURITYLOCAL	44	25
HardcodedNonCryptoSecret	SECURITYLOCAL	37	28
HardcodedSecret	SECURITYLOCAL	44	51
InsecureCipherNoIntegrity	SECURITYLOCAL	24	5
InsecureECB	SECURITYLOCAL	7	2
InsecureHash	SECURITYLOCAL	56	27
InsecureTLSConfig	SECURITYLOCAL	77	8
InsufficientPostmessageValidation	SECURITYLOCAL	14	3
IntrospectionEnabled	SECURITYLOCAL	7	9
LimitGraphQLDepth	SECURITYLOCAL	5	2
LoopDOS	SECURITYLOCAL	3	6
NoCryptoTimingAttacks	SECURITYLOCAL	2	1
NoHardcodedCredentials	SECURITYLOCAL	38	21
NoHardcodedPasswords	SECURITYLOCAL	31	21
NodeBufferNoOffset	SECURITYLOCAL	3	1
TooPermissiveCorsHeader	SECURITYLOCAL	5	9
TooPermissiveCorsPostMessage	SECURITYLOCAL	10	7
TooSmallRsaKeySizeUsed	SECURITYLOCAL	3	1
UseCsrfForExpress	SECURITYLOCAL	46	30
UseHelmetForExpress	SECURITYLOCAL	36	18
UseSecureWebsockets	SECURITYLOCAL	24	27

(table continued)

(table continued)

Issue Identifier	Issue Category	# Datapoints	
		Train	Test
WebCookieHttpOnlyDisabledByDefault	SECURITYLOCAL	14	12
WebCookieHttpOnlyDisabledExplicitly	SECURITYLOCAL	12	6
WebCookieSecureDisabledByDefault	SECURITYLOCAL	54	26
WebCookieSecureDisabledExplicitly	SECURITYLOCAL	8	3
Stats for SECURITYLOCAL: # Issues: 27		1009	539
CodeInjection	SECURITYFLOW	50	67
CommandInjection	SECURITYFLOW	45	23
DOMXSS	SECURITYFLOW	81	51
FormatString	SECURITYFLOW	2	2
HTTPSourceWithUncheckedType	SECURITYFLOW	33	21
IndirectCommandInjection	SECURITYFLOW	11	7
NoRateLimitingForExpensiveWebOperation	SECURITYFLOW	37	9
NoRateLimitingForLogin	SECURITYFLOW	4	10
NoSqli	SECURITYFLOW	7	4
OR	SECURITYFLOW	38	57
PT	SECURITYFLOW	36	18
PrototypePollution	SECURITYFLOW	3	2
ServerLeak	SECURITYFLOW	61	46
Sqli	SECURITYFLOW	43	65
XSS	SECURITYFLOW	128	95
reDOS	SECURITYFLOW	27	25
Stats for SECURITYFLOW: # Issues: 16		606	502
Total stats: # Issues: 156		3532	1818

B Prompts for GPT-3.5 & GPT-4

Let **RULE** and **DESCRIPTION** denote the name and the description of the issue reported by the static analyzer in a code snippet. We will query the model to generate a fix for this code snippet and denote it by $\text{CODE}_{\text{PRE}}^q$. Let f be the number of few-shot examples provided in the prompt and the pair of code snippets $(\text{CODE}_{\text{PRE}}^i, \text{CODE}_{\text{POST}}^i)$ denote the i th example fix for the issue **RULE** in the prompt.

GPT-3.5 and GPT-4 were designed to make conversations and we followed the best practices [31] shared by OpenAI to build the initial conversation. A conversation can contain three different roles, namely system, user and assistant. It is advised to start the conversation with a system content where one defines the role of the assistant (AI model) and gives instructions on the desired output structure. After that, we provide the few-shot examples as a conversation between the user and the assistant. The conversation is finished by the user providing the vulnerable code $\text{CODE}_{\text{PRE}}^q$ so that the next turn belongs to the assistant. The assistant completes the conversation by generating the fix to the last user query. Precisely, the following prompt is fed into GPT models. (The last sentence of the system prompt was not provided when the full file was fed into the model.)

```

Assistant is a code assistant designed to fix issues in given
code snippets. Instructions: Do not generate additional
text or code. Output only the fixed code snippet. Do not
generate explanations, comments, notes. Note that the code
we provide is incomplete, it is intentionally reduced to a
smaller snippet, do not try to complete it in anyway. Leave
everything as it is and just apply the changes related to
the fix.
SYSTEM:
USER: Generate the fixed code for the bug RULE with the
error message DESCRIPTION.  $\text{CODE}_{\text{PRE}}^1$ 
ASSISTANT:  $\text{CODE}_{\text{POST}}^1$ 
...
USER: Generate the fixed code for the bug RULE with the
error message DESCRIPTION.  $\text{CODE}_{\text{PRE}}^f$ 
ASSISTANT:  $\text{CODE}_{\text{POST}}^f$ 
USER: Generate the fixed code for the bug RULE with the
error message DESCRIPTION.  $\text{CODE}_{\text{PRE}}^q$ 

```

C Examples Fixes

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre> const express = require('express') const router = express.Router() const dbConfig = require('../db/dbConfig') const mysql = require('mysql') const pool = mysql.createPool(dbConfig.mysql) let responseJSON = function (res, ret) { if (typeof ret === 'undefined') { res.json({ code: '-200', msg: 'failed operation' }) } else { res.json(ret) } } // ... <REDACTED> router.get('/api', (req, res, next) => { // ... <REDACTED> var obj = { name: 'huangming', age: 1 } res.json(obj) }) // ... <REDACTED> router.get('/postAdvice', (req, res, next) => { res.header('Access-Control-Allow-Origin', '*') res.header('Access-Control-Allow-Methods', 'PUT, GET, POST, DELETE, OPTIONS') res.header('Access-Control-Allow-Headers', 'X-Requested-With') res.header('Access-Control-Allow-Headers', 'Content-Type') let ip = req.headers['x-forwarded-for'] req.connection.remoteAddress req.socket.remoteAddress (req.connection.socket ? req.connection.socket.remoteAddress : null) pool.getConnection((err, connection) => { let param = req.query let sql = 'INSERT INTO w_advice (username,advice,email,ip) \ VALUES ("' \ + param.username + "','" + param.advice \ + "','" + param.email + "','" + ip + '")' connection.query(sql, (err, result) => { responseJSON(res, result) }) connection.release() }) }) </pre>	<pre> const express = require('express') const router = express.Router() const dbConfig = require('../db/dbConfig') const mysql = require('mysql') const pool = mysql.createPool(dbConfig.mysql) let responseJSON = function (res, ret) { if (typeof ret === 'undefined') { res.json({ code: '-200', msg: 'failed operation' }) } else { res.json(ret) } } // ... <REDACTED> router.get('/api', (req, res, next) => { // ... <REDACTED> var obj = { name: 'huangming', age: 1 } res.json(obj) }) // ... <REDACTED> router.get('/postAdvice', (req, res, next) => { res.header('Access-Control-Allow-Origin', '*') res.header('Access-Control-Allow-Methods', 'PUT, GET, POST, DELETE, OPTIONS') res.header('Access-Control-Allow-Headers', 'X-Requested-With') res.header('Access-Control-Allow-Headers', 'Content-Type') let ip = req.headers['x-forwarded-for'] req.connection.remoteAddress req.socket.remoteAddress (req.connection.socket ? req.connection.socket.remoteAddress : null) pool.getConnection((err, connection) => { let param = req.query let sql = 'INSERT INTO w_advice (username,advice,email,ip) \ VALUES (?, ?, ?, ?)' connection.query(sql, [param.username, param.advice, param.email, ip], (err, result) => { responseJSON(res, result) }) connection.release() }) }) </pre>

Figure 6. DEEPCode AI Fix fixes *Sql Injection*, one of the most common and critical vulnerabilities.

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre>// ... <REDACTED> import fs = require('fs') import { type Request, type Response, type NextFunction } from 'express' // ... <REDACTED> module.exports = function profileImageUrlUpload () { return (req: Request, res: Response, next: NextFunction) => { if (req.body.imageUrl !== undefined) { const url = req.body.imageUrl if (url.match(/(.)*solve\/challenges\/server-side(.)*/) !== null) req.app.locals.abused_ssrf_bug = true const loggedInUser = security.authenticatedUsers.get(req.cookies.token) // ... <REDACTED> if (loggedInUser) { const imageRequest = request .get(url) .on('error', function (err: unknown) { // ... <REDACTED> }) .on('response', function (res: Response) { // ... <REDACTED> }) // ... <REDACTED> } } } }</pre>	<pre>// ... <REDACTED> import fs = require('fs') import { type Request, type Response, type NextFunction } from 'express' // ... <REDACTED> module.exports = function profileImageUrlUpload () { return (req: Request, res: Response, next: NextFunction) => { if (req.body.imageUrl !== undefined) { const url = typeof req.body.imageUrl === 'string' ? req.body.imageUrl : '' if (url.match(/(.)*solve\/challenges\/server-side(.)*/) !== null) req.app.locals.abused_ssrf_bug = true const loggedInUser = security.authenticatedUsers.get(req.cookies.token) // ... <REDACTED> if (loggedInUser) { const imageRequest = request .get(url) .on('error', function (err: unknown) { // ... <REDACTED> }) .on('response', function (res: Response) { // ... <REDACTED> }) // ... <REDACTED> } } } }</pre>

Figure 7. DEEPCODE AI FIX fixes a *HTTPSourceWithUncheckedType* vulnerability inside *Juice-Shop*, one of the intentionally vulnerable benchmark repositories.

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre>// ... <REDACTED> const finale = require('finale-rest') const express = require('express') const compression = require('compression') // ... <REDACTED> const models = require('./models') const datacreator = require('./data/datacreator') const app = express() // ... <REDACTED> const collectDurationPromise = (name, func) => { return async (...args) => { const end = startupGauge.startTimer({ task: name }) const res = await func(...args) end() return res } } // ... <REDACTED> /* Sets view engine to hbs */ app.set('view engine', 'hbs') restoreOverwrittenFilesWithOriginals().then(() => { // ... <REDACTED> app.use(errorhandler()) }).catch((err) => { // ... <REDACTED> }) // ... <REDACTED></pre>	<pre>// ... <REDACTED> const finale = require('finale-rest') import csrf = require('csrf') const express = require('express') const compression = require('compression') // ... <REDACTED> const models = require('./models') const datacreator = require('./data/datacreator') const app = express() app.use(csrf({ cookie: true })) // ... <REDACTED> const collectDurationPromise = (name, func) => { return async (...args) => { const end = startupGauge.startTimer({ task: name }) const res = await func(...args) end() return res } } // ... <REDACTED> /* Sets view engine to hbs */ app.set('view engine', 'hbs') restoreOverwrittenFilesWithOriginals().then(() => { // ... <REDACTED> app.use(errorhandler()) }).catch((err) => { // ... <REDACTED> }) // ... <REDACTED></pre>

Figure 8. DEEPCODE AI FIX fixes a *UseCsrfForExpress* vulnerability inside *Juice-Shop*. Note that the import statement for *express*, the definition of the app and its usage can be arbitrarily far away from each other. DEEPCODE AI FIX brings them all in the same range and achieves to modify several places in the file without any issue.

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre> var router = require('express').Router() var vulnDict = require('../config/vulns') var authHandler = require('../core/authHandler') module.exports = function (passport) { router.get('/', authHandler.isAuthenticated, function (req, res) { res.redirect('/learn') }) router.get('/login', authHandler.isNotAuthenticated, function (req, res) { res.render('login') }) // ... <REDACTED> router.get('/learn', authHandler.isAuthenticated, function (req, res) { res.render('learn',{vulnerabilities:vulnDict}) }) router.get('/logout', function (req, res) { req.logout(); res.redirect('/'); }) // ... <REDACTED> router.post('/login', passport.authenticate('login', { successRedirect: '/learn', failureRedirect: '/login', failureFlash: true })) router.post('/register', passport.authenticate('signup', { successRedirect: '/learn', failureRedirect: '/register', failureFlash: true })) // ... <REDACTED> router.post('/resetpw', authHandler.resetPwSubmit) return router } </pre>	<pre> var router = require('express').Router() var vulnDict = require('../config/vulns') var authHandler = require('../core/authHandler') const rateLimit = require('express-rate-limit') module.exports = function (passport) { router.get('/', authHandler.isAuthenticated, function (req, res) { res.redirect('/learn') }) router.get('/login', authHandler.isNotAuthenticated, function (req, res) { res.render('login') }) // ... <REDACTED> router.get('/learn', authHandler.isAuthenticated, function (req, res) { res.render('learn',{vulnerabilities:vulnDict}) }) router.get('/logout', function (req, res) { req.logout(); res.redirect('/'); }) // ... <REDACTED> const loginLimiter = rateLimit({ windowMs: 15 * 60 * 1000, // 15 minutes max: 5 }) router.post('/login', loginLimiter, passport.authenticate('login', { successRedirect: '/learn', failureRedirect: '/login', failureFlash: true })) router.post('/register', passport.authenticate('signup', { successRedirect: '/learn', failureRedirect: '/register', failureFlash: true })) // ... <REDACTED> router.post('/resetpw', authHandler.resetPwSubmit) return router } </pre>

Figure 9. DEEPCODE AI FIX fixes a *NoRateLimiting* vulnerability inside *appsecco/dvna*, one of the intentionally vulnerable benchmark repositories. This is a hard to fix vulnerability because the fix requires changes in 3 different locations of the file and some of those changes involve multiple lines.

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre>// ... <REDACTED> const exec = require('child_process').exec; var mathjs = require('mathjs'); var libxmljs = require("libxmljs"); var serialize = require("node-serialize") const Op = db.Sequelize.Op // ... <REDACTED> module.exports.ping = function (req, res) { exec('ping -c 2 ' + req.body.address, function (err, stdout, stderr) { output = stdout + stderr res.render('app/ping', { output: output }) }) } // ... <REDACTED> module.exports.listProducts = function (req, res) { db.Product.findAll().then(products => { output = { products: products } res.render('app/products', { output: output }) }) } // ... <REDACTED> module.exports.listUsersAPI = function (req, res) { db.User.findAll({}).then(users => { res.status(200).json({ success: true, users: users }) }) } // ... <REDACTED></pre>	<pre>// ... <REDACTED> const exec = require('child_process').exec; var mathjs = require('mathjs'); var libxmljs = require("libxmljs"); var serialize = require("node-serialize") const Op = db.Sequelize.Op // ... <REDACTED> module.exports.ping = function (req, res) { execFile('ping', ['-c', '2', req.body.address], function (err, stdout, stderr) { output = stdout + stderr res.render('app/ping', { output: output }) }) } // ... <REDACTED> module.exports.listProducts = function (req, res) { db.Product.findAll().then(products => { output = { products: products } res.render('app/products', { output: output }) }) } // ... <REDACTED> module.exports.listUsersAPI = function (req, res) { db.User.findAll({}).then(users => { res.status(200).json({ success: true, users: users }) }) } // ... <REDACTED></pre>

Figure 10. DEEPCODE AI FIX fixes a *CommandInjection* vulnerability inside *appsecco/dvna*, one of the intentionally vulnerable benchmark repositories. Note how DEEPCODE AI FIX keeps the required import during reduction and the significant compression rate.

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre> var express = require('express') var bodyParser = require('body-parser') var passport = require('passport') var session = require('express-session') var ejs = require('ejs') var morgan = require('morgan') const fileUpload = require('express-fileupload'); var config = require('./config/server') //Initialize Express var app = express() require('./core/passport')(passport) app.use(express.static('public')) app.set('view engine','ejs') app.use(morgan('tiny')) app.use(bodyParser.urlencoded({ extended: false })) app.use(fileUpload()); // Enable for Reverse proxy support // app.set('trust proxy', 1) // Initialize Session app.use(session({ secret: 'keyboard cat', resave: true, saveUninitialized: true, cookie: { secure: false } })) // Routing app.use('/app',require('./routes/app'))() app.use('/',require('./routes/main')(passport)) // Start Server app.listen(config.port, config.listen) </pre>	<pre> var express = require('express') var bodyParser = require('body-parser') var passport = require('passport') var session = require('express-session') var ejs = require('ejs') var morgan = require('morgan') const fileUpload = require('express-fileupload'); var config = require('./config/server') //Initialize Express var helmet = require('helmet') var app = express() require('./core/passport')(passport) app.use(express.static('public')) app.set('view engine','ejs') app.use(morgan('tiny')) app.use(bodyParser.urlencoded({ extended: false })) app.use(fileUpload()); // Enable for Reverse proxy support // app.set('trust proxy', 1) // Initialize Session app.use(session({ secret: 'keyboard cat', resave: true, saveUninitialized: true, cookie: { secure: false } })) // Routing app.use('/app',require('./routes/app'))() app.use(helmet()) app.use('/',require('./routes/main')(passport)) // Start Server app.listen(config.port, config.listen) </pre>

Figure 11. DEEP CODE AI Fix fixes a *UseHelmetForExpress* vulnerability inside *appsecco/dvna*. The fix is seemingly simple as one can add *helmet* with a single line. However, without adding the right import statement, the code will be broken. A great bug-fixing tool must apply imports correctly. This makes even the seemingly simple fix patterns much harder as the import statements and their usages can be arbitrarily far away from each other. The rule *UseHelmetForExpress* belongs to the category *SecurityLocal* but it still requires changes in several different places of the file, just like other "*Local*" rules.

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre> 'user strcit'; const config = require('.././../config') var jwt = require("jsonwebtoken"); const { user } = require('.././orm'); module.exports = (app,db) => { app.post('/v1/user/token', (req,res) =>{ // ... <REDACTED> }); app.post('/v1/user/login', (req,res) =>{ // ... REDACTED const user = db.user.findAll({ where: { email: userEmail }).then(user => { // ... REDACTED }); // ... REDACTED }); app.put('/v1/admin/promote/:id', (req,res) =>{ const userId = req.params.id; const user = db.user.update({role:'admin'}, { where: { id : userId } }) .then((user)=>{ res.send(user) }) }); app.post('/v1/user/:id/validate-otp', (req,res) =>{ // ... REDACTED const user = db.user.findOne({ where: { id: userId }).then(user => { // ... REDACTED }) // ... REDACTED }); }; </pre>	<pre> 'user strcit'; const config = require('.././../config') var jwt = require("jsonwebtoken"); const { user } = require('.././orm'); module.exports = (app,db) => { app.post('/v1/user/token', (req,res) =>{ // ... <REDACTED> }); app.post('/v1/user/login', (req,res) =>{ // ... REDACTED const user = db.user.findAll({ where: { email: userEmail }).then(user => { // ... REDACTED }); // ... REDACTED }); app.put('/v1/admin/promote/:id', (req,res) =>{ const userId = req.params.id; const user = db.user.update({role:'admin'}, { where: { id : userId } }) .then((user)=>{ res.status(200).json(user) }) }); app.post('/v1/user/:id/validate-otp', (req,res) =>{ // ... REDACTED const user = db.user.findOne({ where: { id: userId }).then(user => { // ... REDACTED }) // ... REDACTED }); }; </pre>

Figure 12. DEEP CODE AI Fix fixes a XSS vulnerability inside *SirAppSec/vuln-node.js-express.js-app*, one of the intentionally vulnerable benchmark repositories.

(a) Input: vulnerable pre-version	(b) Output: non-vulnerable full file
<pre>var requirejs = require('requirejs'); var config = requirejs('./config'); // ... <REDACTED> var express = require('express'), http = require('http'), path = require('path'); // ... <REDACTED> var rootDir = path.join(__dirname, '..'); var app = express(); app.configure(function(){ app.set('port', process.env.PORT 3000); app.use(express.logger('dev')); // ... <REDACTED> }); app.configure('development', function(){ app.use('/app', express.static(path.join(rootDir, 'app'))); // ... <REDACTED> }); var server = http.createServer(app) .listen(app.get('port'), function(){ console.log("<REDACTED> " + app.get('port')); });</pre>	<pre>var requirejs = require('requirejs'); var config = requirejs('./config'); // ... <REDACTED> var express = require('express'), https = require('https'), path = require('path'); // ... <REDACTED> var rootDir = path.join(__dirname, '..'); var app = express(); app.configure(function(){ app.set('port', process.env.PORT 3000); app.use(express.logger('dev')); // ... <REDACTED> }); app.configure('development', function(){ app.use('/app', express.static(path.join(rootDir, 'app'))); // ... <REDACTED> }); var server = https.createServer(app) .listen(app.get('port'), function(){ console.log("<REDACTED> " + app.get('port')); });</pre>

Figure 13. DEEPCODE AI Fix fixes a *HttpToHttps* vulnerability requiring multiple changes in different locations of the file.

D Evaluation of Model Size and Architecture with CodeReduce

Table 7. Effects of the model size and architecture for CODEREDUCED data, w.r.t. PASS@ k for $k = 1$.

Issue Category	PASS@ k (%), $k = 1$		
	STARCODERBASE-1B	STARCODERBASE-7B	MISTRAL-7B-INSTRUCT
AST	59.00	<u>70.05</u>	63.78
LOCAL	72.02	<u>82.75</u>	70.09
FILEWIDE	54.28	<u>77.38</u>	51.48
SECURITYLOCAL	67.06	<u>74.68</u>	56.33
SECURITYFLOW	39.64	<u>49.15</u>	27.47

E Evaluation of Different Models with CodeReduce

Table 8. Evaluation of PASS@ k and EXACTMATCH@ k metrics for models that use CODEREDUCE (marked as ‡)

Issue Category	Model	PASS@ k (%)			EXACTMATCH@ k (%)		
		$k = 1$	$k = 3$	$k = 5$	$k = 1$	$k = 3$	$k = 5$
AST	MIXTRAL-8x7B-CODEREDUCED [‡]	81.01	88.96	89.16	39.29	52.25	53.5
	STARCODER-7B-CODEREDUCED [‡]	70.05	80.84	82.31	41.19	48.15	48.56
	STARCODER-3B-CODEREDUCED [‡]	68.2	78.86	81.84	40.51	43.79	43.79
	STABLECODE-3B-CODEREDUCED [‡]	67.21	79.77	80.6	37.69	46.51	47.02
	DEEPSEEKCODER-1.3B-CODEREDUCED [‡]	57.39	75.41	79.27	30.75	39.67	45.48
LOCAL	MIXTRAL-8x7B-CODEREDUCED [‡]	69.77	90.19	92.71	31.37	41.77	44.11
	STARCODER-7B-CODEREDUCED [‡]	82.75	89.72	90.19	34.23	42.02	42.73
	STARCODER-3B-CODEREDUCED [‡]	81.87	85.82	87.63	33.99	40.79	44.02
	STABLECODE-3B-CODEREDUCED [‡]	77.51	83.39	83.93	32.18	39.72	40.72
	DEEPSEEKCODER-1.3B-CODEREDUCED [‡]	72.72	82.24	85.05	33.98	42.97	45.4
FILEWIDE	MIXTRAL-8x7B-CODEREDUCED [‡]	50.37	67.61	85.66	41.66	47.91	48.95
	STARCODER-7B-CODEREDUCED [‡]	77.38	80.16	85.02	44.59	54.5	54.5
	STARCODER-3B-CODEREDUCED [‡]	61.88	81.9	82.59	38.69	57.91	73.11
	STABLECODE-3B-CODEREDUCED [‡]	69.74	76.34	76.34	38.4	40.98	40.98
	DEEPSEEKCODER-1.3B-CODEREDUCED [‡]	64.98	89.29	94.89	34.53	62.91	65.27
SECURITYLOCAL	MIXTRAL-8x7B-CODEREDUCED [‡]	63.58	92.2	94.41	15.77	23.46	25.99
	STARCODER-7B-CODEREDUCED [‡]	74.68	89.08	91.76	20.18	29.53	32.23
	STARCODER-3B-CODEREDUCED [‡]	68.04	88.51	91.41	17.86	25.6	27.43
	STABLECODE-3B-CODEREDUCED [‡]	70.94	84.23	86.49	15.31	18.71	23.36
	DEEPSEEKCODER-1.3B-CODEREDUCED [‡]	61.69	84.18	88.66	15.99	26.84	28.82
SECURITYFLOW	MIXTRAL-8x7B-CODEREDUCED [‡]	41.93	72.97	81.62	9.26	17.9	20.27
	STARCODER-7B-CODEREDUCED [‡]	49.15	65.9	68.53	10.63	13.49	15.7
	STARCODER-3B-CODEREDUCED [‡]	45.65	58.82	65.99	9.72	16.17	21.07
	STABLECODE-3B-CODEREDUCED [‡]	41.28	55.32	58.58	9.86	15.37	15.78
	DEEPSEEKCODER-1.3B-CODEREDUCED [‡]	33.26	59.61	66.88	15.22	19.27	19.77